

MEDIROZA GENERAL HOSPITAL

Penetration Testing & Vulnerability Assessment

MILESTONE 4 — DETAILED PENETRATION TESTING REPORT

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Assessment Type	Black-box Web Application Penetration Test & Vulnerability Assessment
Assessment Period	5 days
Authorization	Written authorization stated as granted
Report Status	Draft — based on evidence collected during the assessment

CONFIDENTIAL — AUTHORISED PERSONNEL ONLY

1. Executive Summary

A penetration test was conducted against the Mediroza General Hospital web infrastructure within the authorized scope. The assessment identified a publicly accessible directory containing a database backup file. The exposed backup, **mediroza_db_backup_2019.sql**, was accessible through the **/old/** directory and contained sensitive hospital information.

The recovered database demonstrated exposure of:

- Hospital employee names and job titles
- Departments
- Email addresses and telephone numbers
- Salary information
- Shareholder names
- Shareholding percentages and shares held
- Share classes

The primary security issue is the public exposure of a database backup. The impact is increased because the backup contains structured employee, financial and corporate ownership information.

The requested **/well-known/security.txt** resource returned a 404 response. This was recorded as an informational observation and was not treated as a primary vulnerability because the collected evidence did not demonstrate direct security impact from the missing file.

The project also requested retrieval and decryption of three confidential PDF patient reports. **No evidence collected during the assessment demonstrates successful retrieval or decryption of those three PDFs**, so those objectives are not represented as completed findings.

2. Scope and Methodology

2.1 Scope

The project documentation identifies the target as **https://medirozahospital.com**. The authorized scope was the target domain and associated web infrastructure.

- Testing limited to the target domain
- No social engineering
- No denial-of-service testing
- No testing outside the agreed scope

Written authorization was stated as granted by the client.

2.2 Methodology

The assessment followed the project milestones supplied for the exercise: reconnaissance and initial access, file analysis, data-exposure analysis, and reporting.

Milestone 1 — Reconnaissance and initial access. Reconnaissance included examination of exposed entry points, application behavior, access controls and server-side resources. An exposed **/old/** directory was discovered.

Milestone 2 — File analysis. The project required recovery and decryption of three encrypted PDF files. The available evidence does not demonstrate successful retrieval of those three files.

Milestone 3 — Data exposure analysis. The discovered database backup was obtained and analyzed. The SQL dump contained staff and shareholder data.

Milestone 4 — Reporting. Findings are documented with evidence, impact, risk ratings and remediation recommendations.

3. Findings and Proof of Exploitation

F-01 — Public Directory Listing Exposes Database Backup

Severity: High

The **/old/** directory was accessible without authentication and exposed a directory listing. The listing revealed the database backup file **mediroza_db_backup_2019.sql**.

Observed evidence:

```
Index of /old/  
mediroza_db_backup_2019.sql
```

An unauthenticated visitor able to enumerate this directory could identify and retrieve the database backup. The weakness therefore provides a direct path from web-server misconfiguration to sensitive database disclosure.

Impact: Exposure of sensitive employee and corporate information.

Risk: High

F-02 — Sensitive Employee Information Exposed in Database Backup

Severity: High

Analysis of the SQL dump showed a **staff** table containing employee records with fields including full name, job title, department, email, phone and salary.

The SQL evidence included INSERT statements for staff records.

This creates potential exposure of employee privacy, organisational structure, compensation information, and information useful for targeted phishing or social-engineering activity.

Risk: High

F-03 — Hospital Shareholder Information Exposed

Severity: High

The recovered database contained a **shareholders** table with the fields **shareholder_name**, **share_percent**, **shares_held** and **share_class**.

Observed table structure:

```
CREATE TABLE `shareholders`  
  shareholder_name  
  share_percent  
  shares_held  
  share_class
```

The evidence showed ten shareholder records, including individuals, a company and a family trust, with ownership percentages and share counts.

Impact: Disclosure of confidential business and ownership information.

Risk: High

F-04 — Directory Listing / Backup Management Weakness

Severity: Medium

The **/old/** directory was configured so that its contents could be enumerated through a browser. Directory indexing can disclose backup files, old application versions, configuration files and temporary artifacts. In this case it materially assisted discovery of a database backup.

Risk: Medium

Informational Observation — Missing security.txt

The requested **/well-known/security.txt** resource returned **404 Not Found**. This is recorded as informational only because the evidence does not demonstrate a direct compromise resulting from the missing resource.

4. Milestone Status

Milestone	Objective	Status
M1	Reconnaissance and retrieve three confidential PDF reports	Partially completed / not demonstrated
M2	Crack encryption on all three retrieved files	Not demonstrated
M3	Identify critical data exposure on client server	Completed
M4	Produce penetration-testing report	Completed in this draft

5. Risk Summary

ID	Finding	Severity
F-01	Publicly accessible database backup	High
F-02	Employee and salary information exposed	High
F-03	Shareholder information exposed	High
F-04	Directory listing exposes server contents	Medium
INFO-01	security.txt unavailable	Informational

6. Recommendations and Remediation

6.1 Remove the exposed database backup

Immediately remove **/old/mediroza_db_backup_2019.sql** from the publicly accessible web directory.

6.2 Disable directory listing

Disable directory indexing for web-accessible directories so that server contents cannot be enumerated through automatic directory listings.

6.3 Store backups outside the web root

Database backups should be stored in protected backup storage that is not directly reachable through HTTP/HTTPS.

6.4 Review historical and temporary directories

Review **/old/** and other legacy directories for **.sql**, **.zip**, **.tar**, **.gz**, **.bak**, **.old**, configuration and environment files. Remove unnecessary artifacts.

6.5 Rotate potentially exposed credentials

Determine whether the exposed backup contains database credentials, application credentials, API keys, password hashes, encryption keys or service credentials. Rotate any exposed secrets.

6.6 Review backup procedures

Use controlled backup storage, appropriate access restrictions, encryption at rest, retention policies and secure deletion/archival procedures.

6.7 Review exposed employee information

Assess whether the disclosed employee information was accessed by unauthorized parties and review whether additional sensitive records exist in other accessible backups.

6.8 Review shareholder information exposure

Assess the business confidentiality implications and review other historical backups or endpoints for similar ownership information.

6.9 Add security monitoring

Monitor for unexpected files in web roots, directory indexes, publicly accessible backups, unusual downloads and access to administrative or backup paths.

7. Evidence Collected

Evidence 1 — Project scope

The project material identifies Mediroza General Hospital, target <https://medirozahospital.com>, a penetration testing and vulnerability assessment, a five-day timeline, and stated written authorization.

Evidence 2 — Public /old/ directory

Browser evidence showed an Index of /old/ page with mediroza_db_backup_2019.sql listed.

Evidence 3 — SQL database contents

The recovered SQL file was opened in Visual Studio Code and showed the staff table and employee records.

Evidence 4 — Shareholder table

The SQL file contained a shareholders table with shareholder_name, share_percent, shares_held and share_class fields and associated records.

Evidence 5 — security.txt response

The requested /well-known/security.txt resource returned 404 Not Found.

8. Conclusion

The assessment demonstrated a significant information-disclosure issue within the authorized target. The primary weakness was public exposure of an old database backup through the /old/ directory. Analysis of that backup demonstrated exposure of employee information, salary information and hospital shareholder information.

The primary remediation actions are to remove publicly accessible backups, disable directory indexing, relocate backups outside the web root, review exposed secrets and assess whether additional sensitive information is present in other historical or temporary files.

The available evidence does not demonstrate successful retrieval or decryption of the three confidential PDF patient reports specified in Milestones 1 and 2; those activities are therefore not represented as successful

findings.

Overall assessment conclusion: the discovered backup exposure represents a significant confidentiality risk and should be remediated promptly.

Appendix A — Evidence Notes

This report is a draft prepared from the evidence supplied during the assessment, including the project screenshots and the recovered SQL backup shown during analysis. Where the evidence did not demonstrate successful completion of an activity, the report explicitly states that limitation rather than treating the activity as completed.

End of Report